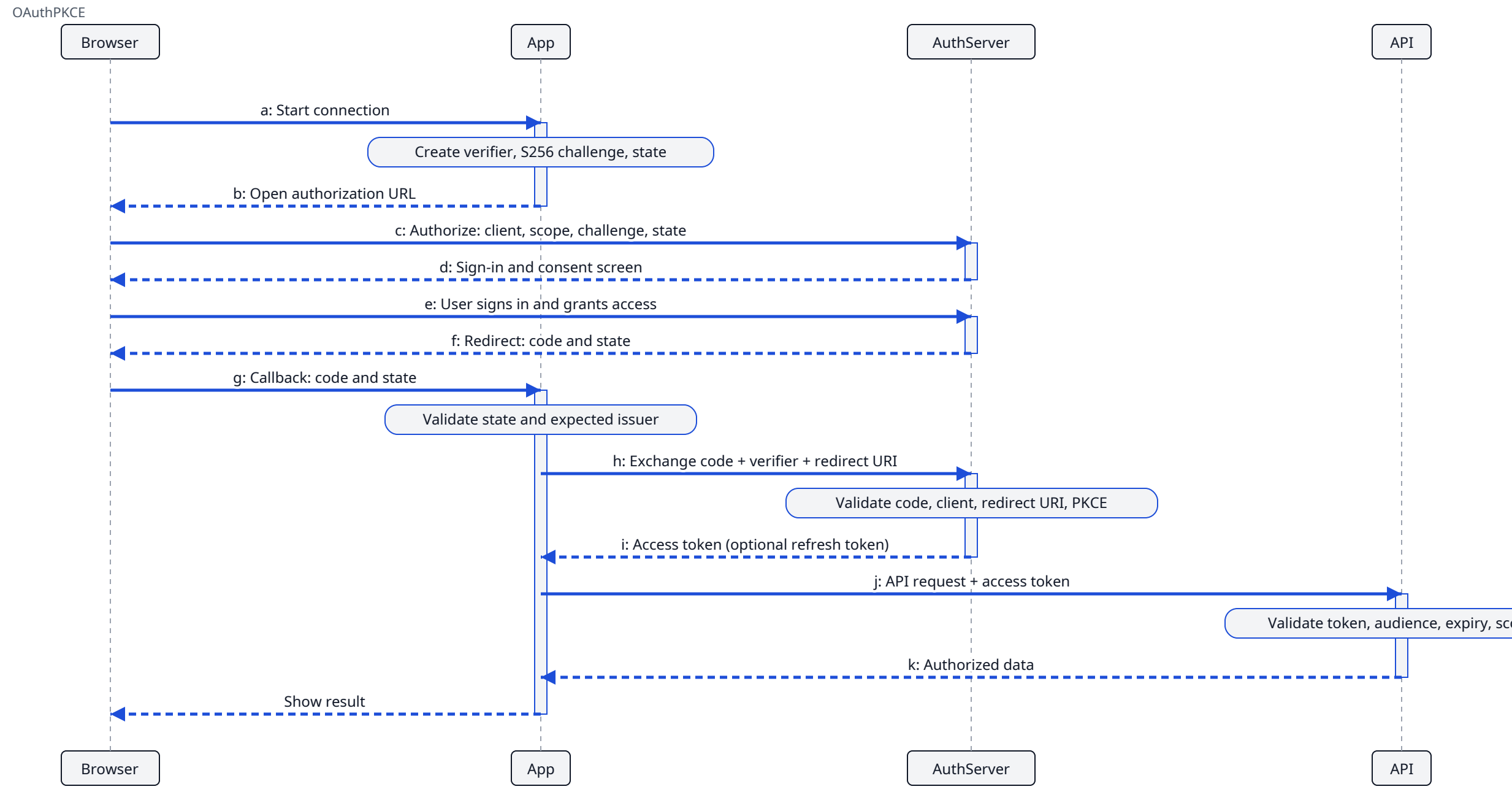

OAuthPKCE
Browser
App
AuthServer
API
a: Start connection
Create verifier, S256 challenge, state
b: Open authorization URL
c: Authorize: client, scope, challenge, state
d: Sign-in and consent screen
e: User signs in and grants access
f: Redirect: code and state
g: Callback: code and state
Validate state and expected issuer
h: Exchange code + verifier + redirect URI
Validate code, client, redirect URI, PKCE
i: Access token (optional refresh token)
j: API request + access token
Validate token, audience, expiry, sc
k: Authorized data
Show result
Browser
App
AuthServer
API